KOMDIGI CSIRT

VA/PT Request Report

TLP: RED

Nomor: 021/3/KCSIRT/02/2025

Scope

Request ID	15795
Target	geoportal.kominfo.go.id
Used Credentials	-
Generate On	04 Februari 2025
Tools	Burp Suite
Pentester	Matthew
Client / User	-

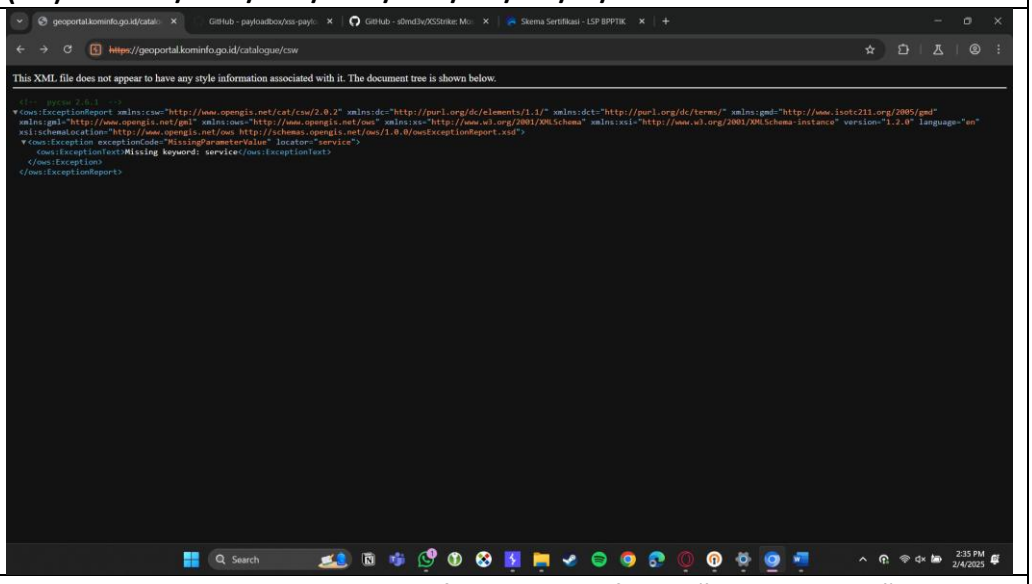
Summary of Alerts

Risk Level	Critical	High	Medium	Low
Number of Alerts	-	1	2	-

Alerts

Vulnerability Name	Risk Level	CVSS Score
XPath Injection	High	(8.6) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:L
TLS cookie without secure flag set	Medium	(4.3) CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N
Client-side HTTP parameter pollution (reflected)	Medium	(5.4) CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N

High	XPath Injection
Description	The **mode** parameter appears to be vulnerable to XPath injection attacks. The payload ' was submitted in the mode parameter, and an XPath error message was returned. You should review the contents of the error message, and the application's handling of other input, to confirm whether a vulnerability is present. XPath injection vulnerabilities arise when user-controllable data is incorporated into XPath queries in an unsafe manner. An attacker can supply crafted input to break out of the data context in which their input appears and interfere with the structure of the surrounding query. Depending on the purpose for which the vulnerable query is being used, an attacker may be able to exploit an XPath injection flaw to read sensitive application data or interfere with application logic.

Solution	User input should be strictly validated before being incorporated into XPath queries. In most cases, it will be appropriate to accept input containing only short alphanumeric strings. At the very least, input containing any XPath metacharacters such as " ' / @ = * [ ] (and) should be rejected.
URL	https://geoportal.kominfo.go.id/catalogue/csw
CVSS Score	**(8.6) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:L**
Screenshot	
Reference	• CWE-94: Improper Control of Generation of Code ('Code Injection') • CWE-116: Improper Encoding or Escaping of Output • CWE-159: Failure to Sanitize Special Element • CWE-643: Improper Neutralization of Data within XPath Expressions ('XPath Injection') • CAPEC-83: XPath Injection

Medium	**TLS cookie without secure flag set**
Description	The following cookie was issued by the application and does not have the secure flag set: • **csrftoken** The cookie appears to contain a session token, which may increase the risk associated with this issue. You should review the contents of the cookie to determine its function.This issue was found in multiple locations under the reported path. If the secure flag is set on a cookie, then browsers will not submit the cookie in any requests that use an unencrypted HTTP connection, thereby preventing the cookie from being trivially intercepted by an attacker monitoring network traffic. If the secure flag is not set, then the cookie will be transmitted in clear-text if the user visits any HTTP URLs within the cookie's scope. An attacker may be able to induce this event by feeding a user suitable links, either directly or via another web site. Even if the domain that issued the cookie does not host any content that is accessed over HTTP, an attacker may be able to use links of the form http://example.com:443/ to perform the same attack. To exploit this vulnerability, an attacker must be suitably positioned to eavesdrop on the victim's network traffic. This scenario typically occurs when a client communicates with the server over an insecure connection such as public Wi-Fi, or a corporate or home network that is shared with a compromised computer. Common defenses such as switched networks are not sufficient to prevent this. An attacker situated in the user's ISP or the application's hosting infrastructure could also perform this attack.

	Note that an advanced adversary could potentially target any connection made over the Internet's core infrastructure.
Solution	The secure flag should be set on all cookies that are used for transmitting sensitive data when accessing content over HTTPS. If cookies are used to transmit session tokens, then areas of the application that are accessed over HTTPS should employ their own session handling mechanism, and the session tokens used should never be transmitted over unencrypted communications.
URL	https://geoportal.kominfo.go.id/catalogue/csw
CVSS Score	**(4.3) CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N**
Reference	• CWE-614: Sensitive Cookie in HTTPS Session Without 'Secure' Attribute

Medium	**Client-side HTTP parameter pollution (reflected)**
Description	The value of the URL path folder 1 is copied into the response within the query string of a URL. The payload **vdg&zaw=1** was submitted in the URL path folder 1. This input was echoed as **vdg&zaw=1** within the "action" attribute of a "form" tag. This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response. Client-side HTTP parameter pollution (HPP) vulnerabilities arise when an application embeds user input in URLs in an unsafe manner. An attacker can use this vulnerability to construct a URL that, if visited by another application user, will modify URLs within the response by inserting additional query string parameters and sometimes overriding existing ones. This may result in links and forms having unexpected side effects. For example, it may be possible to modify an invitation form using HPP so that the invitation is delivered to an unexpected recipient. The security impact of this issue depends largely on the nature of the application functionality. Even if it has no direct impact on its own, an attacker may use it in conjunction with other vulnerabilities to escalate their overall severity.
Solution	Ensure that user input is URL-encoded before it is embedded in a URL.
URL	https://geoportal.kominfo.go.id/api/v2/facets
CVSS Score	**(5.4) CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N**
Reference	• CWE-233: Improper Handling of Parameters • CWE-20: Improper Input Validation • CAPEC-460: HTTP Parameter Pollution (HPP)